

PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	Make 2-3 notes of specific business requirements that will be analyzed. <i>Create a secure and user-friendly marketplace app that connects sneaker buyers and sellers, allowing easy account creation, login, and account management.</i> <i>Protect user data and ensure privacy so users feel confident that their personal and payment information is handled responsibly.</i> <i>Enable smooth and trustworthy transactions by supporting messaging between buyers and sellers, seller ratings, and multiple secure payment options.</i>
II. Define the technical scope	List of technologies used by the application: • <i>Application programming interface (API)</i> • <i>Public key infrastructure (PKI)</i> • <i>SHA-256</i> • <i>SQL</i> Write 2-3 sentences (40-60 words) that describe why you choose to prioritize that technology over the others. I would prioritize evaluating the API first because it acts as the main communication layer between the mobile app, users, and backend services. If the API is insecure, attackers could intercept data, bypass authentication, or access sensitive information stored in the database. Since many app functions depend on the API, weaknesses there could expose the entire system.
III. Decompose application	Sample data flow diagram
IV. Threat analysis	List 2 types of threats in the PASTA worksheet that are risks to the information being handled by the application.

	<i>SQL injection attacks: A threat actor could exploit vulnerabilities in the app's SQL queries to access or modify sensitive data in the database, such as user accounts, passwords, or payment information.</i> <i>Credential theft or phishing: Attackers could use phishing or social engineering to steal user or employee login credentials, allowing unauthorized access to accounts and sensitive personal or financial information.</i>
V. Vulnerability analysis	List 2 vulnerabilities in the PASTA worksheet that could be exploited. <i>Weak API authentication or authorization: If the API does not properly validate authentication tokens or enforce authorization rules, attackers could gain unauthorized access to user accounts or sensitive data.</i> <i>SQL injection vulnerability: If user input is not properly validated or sanitized before being used in SQL queries, attackers could manipulate database queries to view, modify, or delete sensitive information such as user data or payment records.</i>
VI. Attack modeling	Sample attack tree diagram
VII. Risk analysis and impact	List 4 security controls that you've learned about that can reduce risk. Multi-factor authentication (MFA): Require users to verify their identity using an additional factor (such as a code sent to their phone) to reduce the risk of unauthorized account access. Encryption for data in transit and at rest: Use strong encryption methods like TLS, AES, and RSA to protect sensitive information such as passwords and payment data. Input validation and parameterized queries: Validate user input and use prepared SQL statements to prevent attacks like SQL injection. Security monitoring and logging: Implement system logs and monitoring tools to detect suspicious activity and respond quickly to potential threats.